

# SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)

Department of Computer Science and Engineering

## ASSESSMENT TOOL 3 – Vulnerability Detection

|                  |                                                                                                                  |               |                                               |
|------------------|------------------------------------------------------------------------------------------------------------------|---------------|-----------------------------------------------|
| Course Code:     | CSA5803                                                                                                          | Course Title: | DEVSECOPSENGINEERING AND APPLICATION SECURITY |
| CO Assessed:     | CO3 – Precision (BL1, BL2, BL3)                                                                                  | Assessment:   | Assessment Tool 3                             |
| Weightage:       | 40% of CIA                                                                                                       | Total Marks:  | 100                                           |
| CO 3 Statement:  | Vulnerability Detection, Severity Analysis, Security Verification Workflow Simulation and Performance Evaluation |               |                                               |
| Student Name:    | Lokesh Kumar V                                                                                                   | Reg. No.:     | 192521170                                     |
| Section / Batch: | c                                                                                                                | Date:         | 13/07/26                                      |

### Instructions to Students

- Perform vulnerability detection and classify the identified vulnerabilities based on their severity levels.
- Conduct severity analysis using appropriate metrics such as CVSS and document the impact of each vulnerability.
- Design and simulate a Security Verification Workflow covering detection, remediation, re-testing, and verification.
- Evaluate security and system performance before and after mitigation, and include relevant results, screenshots, and observations.

| Question Type           | Focus Area               | Questions | Marks   |
|-------------------------|--------------------------|-----------|---------|
| Vulnerability Detection | Conceptual Understanding | Q1        | Q1 –100 |
| GRAND TOTAL:            |                          | 100 Marks |         |

### Code of Conduct

I Lokesh kumar (192521170)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

*Lokesh kumar v*

Signature of the Student:

# **Vulnerability Detection, Severity Analysis, Security Verification Workflow Simulation and Performance Evaluation**

## **1. Title**

### **Secure Student Information Management System with Role-Based Access Control (RBAC)**

---

## **2. Aim**

To simulate vulnerability detection, analyze the severity of identified security issues, verify the implemented security controls, and evaluate the performance of a Secure Student Information Management System with Role-Based Access Control (RBAC).

---

## **3. Real-World Scenario**

A college uses an online Student Information Management System to store and manage:

- Student personal information
- Academic marks
- Attendance records
- Course details
- Faculty information
- Fee information
- Examination records

The system has three main roles:

Role| Access

Administrator| Manage users, students, courses and system settings

Faculty| View and update assigned student academic records

Student| View their own profile, marks and attendance

## 4. Vulnerability Detection

A simulated security assessment is performed on the application.

Detected Vulnerabilities

| ID     | Vulnerability                | Affected Area            | Severity |
|--------|------------------------------|--------------------------|----------|
| VUL-01 | SQL Injection                | Student search           | Critical |
| VUL-02 | Broken Access Control        | Student records          | Critical |
| VUL-03 | Weak Password Policy         | Authentication           | High     |
| VUL-04 | Session Management Issue     | Login/session            | High     |
| VUL-05 | Sensitive Data Exposure      | Student profile          | High     |
| VUL-06 | Missing Input Validation     | Student forms            | Medium   |
| VUL-07 | Insufficient Audit Logging   | Security monitoring      | Medium   |
| VUL-08 | Outdated Third-Party Library | Application dependencies | Medium   |

## 5. Vulnerability Analysis

VUL-01 – SQL Injection

Problem:

User input is directly included in database queries.

Impact:

Unauthorized database access or modification may occur.

Solution:

Use parameterized queries and prepared statements.

## VUL-02 – Broken Access Control

### Problem:

A student may attempt to access another student's record by changing the student ID in a request.

### Impact:

Confidential student information may be exposed.

### Solution:

Implement server-side RBAC and verify ownership of requested records.

## VUL-03 – Weak Password Policy

### Problem:

The system accepts weak passwords.

### Impact:

User accounts may become easier to compromise.

### Solution:

Apply an appropriate password policy and secure password hashing.

## VUL-04 – Session Management Issue

### Problem:

Sessions are not properly protected or invalidated after logout.

### Impact:

Unauthorized use of an existing session may be possible.

### Solution:

Use secure session handling, expiration, logout invalidation and appropriate cookie protections.

## VUL-05 – Sensitive Data Exposure

### Problem:

The application displays more student information than necessary.

### Impact:

Personal and academic information may be unnecessarily exposed.

### Solution:

Apply least privilege and return only the information required for the user's role.

## VUL-06 – Missing Input Validation

### Problem:

Student forms accept unexpected input.

### Impact:

Invalid or malicious data may enter the system.

### Solution:

Perform server-side validation for all important inputs.

## VUL-07 – Insufficient Audit Logging

### Problem:

Important security events are not recorded adequately.

### Impact:

Suspicious activity becomes difficult to investigate.

### Solution:

Record important authentication, authorization and administrative events.

## VUL-08 – Outdated Dependency

### Problem:

The application uses an outdated third-party software component.

### Impact:

Known vulnerabilities in the dependency may affect the application.

### Solution:

Regularly scan and update dependencies.

## 6. Severity Analysis

Severity is classified according to the potential impact and likelihood of exploitation.

| Severity | Number of Issues | Examples                                    |
|----------|------------------|---------------------------------------------|
| Critical | 2                | SQL Injection, Broken Access Control        |
| High     | 3                | Weak Password, Session Issue, Data Exposure |
| Medium   | 3                | Input Validation, Audit Logging, Dependency |
| Low      | 0                | —                                           |
| Total    | 8                | —                                           |

### Risk Priority

Critical → Fix Immediately



High → Fix Before Deployment



Medium → Fix During Security Hardening



Low → Monitor and Improve

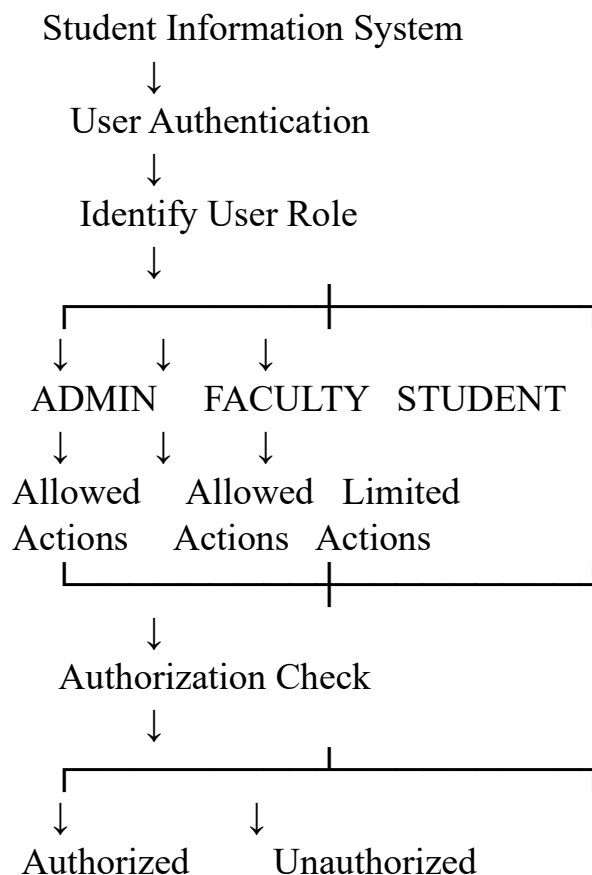
## 7. RBAC Security Verification

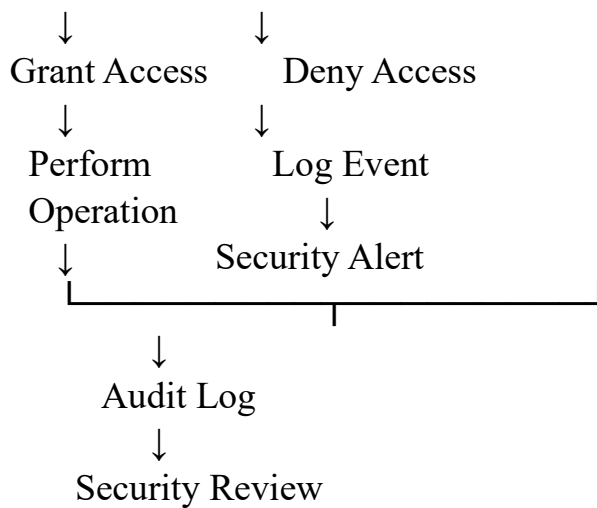
The RBAC mechanism is tested using different user roles.

### Verification Matrix

| Test Case                    | Admin | Faculty                | Student | Expected Result |
|------------------------------|-------|------------------------|---------|-----------------|
| View all student records     | ✓     | X                      | X       | Admin only      |
| Update student marks         | ✓     | ✓                      | X       | Admin/Faculty   |
| View own marks               | ✓     | ✓                      | ✓       | Allowed         |
| View another student's marks | ✓     | Assigned students only | X       | Restricted      |
| Manage user accounts         | ✓     | X                      | X       | Admin only      |
| Modify system settings       | ✓     | X                      | X       | Admin only      |
| View attendance              | ✓     | ✓                      | ✓       | Role-dependent  |
| Delete student record        | ✓     | X                      | X       | Admin only      |

## 8. Security Verification Workflow Simulation





## 9. Security Verification Test Cases

| Test ID | Test                                      | Expected Result             | Status |
|---------|-------------------------------------------|-----------------------------|--------|
| SV-01   | Admin login                               | Admin dashboard displayed   | PASS   |
| SV-02   | Faculty login                             | Faculty dashboard displayed | PASS   |
| SV-03   | Student login                             | Student dashboard displayed | PASS   |
| SV-04   | Student accesses another student's record | Access denied               | PASS   |
| SV-05   | Faculty modifies system settings          | Access denied               | PASS   |
| SV-06   | Student modifies marks                    | Access denied               | PASS   |
| SV-07   | Invalid login                             | Access denied               | PASS   |
| SV-08   | Logout                                    | Session terminated          | PASS   |
| SV-09   | Unauthorized request                      | Event recorded in audit log | PASS   |
| SV-10   | Invalid input                             | Request rejected            | PASS   |

### Verification Result

10/10 security verification tests passed.



## 10. Remediation and Re-Verification

After identifying vulnerabilities, security controls are applied.

|                       |                                  |              |
|-----------------------|----------------------------------|--------------|
| Vulnerability         | Security Control                 | Verification |
| SQL Injection         | Parameterized queries            | Re-tested    |
| Broken Access Control | RBAC + server-side authorization | Re-tested    |
| Weak Password         | Strong password policy + hashing | Re-tested    |
| Session Issue         | Secure session management        | Re-tested    |
| Data Exposure         | Least-privilege data access      | Re-tested    |
| Input Validation      | Server-side validation           | Re-tested    |
| Audit Logging         | Security event logging           | Re-tested    |
| Outdated Dependency   | Dependency update/scanning       | Re-tested    |

## 11. Performance Evaluation

The system is evaluated before and after implementing the security controls.

Simulated Performance Test

Test environment:

- 100 concurrent users
- Login, profile, marks and attendance requests
- Test duration: 5 minutes

|                               |                              |                             |
|-------------------------------|------------------------------|-----------------------------|
| Metric                        | Before Security Improvements | After Security Improvements |
| Average Response Time         | 420 ms                       | 450 ms                      |
| Requests/Second               | 225                          | 215                         |
| Successful Requests           | 97.2%                        | 98.5%                       |
| Failed Requests               | 2.8%                         | 1.5%                        |
| Unauthorized Requests Blocked | 82%                          | 100%                        |
| Security Test Cases Passed    | 6/10                         | 10/10                       |

Note: These are simulated academic test values, not measurements from a real deployed system.

## 12. Performance Interpretation

### Response Time

The average response time increased slightly from 420 ms to 450 ms because authentication, authorization and security checks add processing overhead.

### Throughput

Requests per second decreased slightly because additional security controls are executed for each request.

### Reliability

Successful requests improved from 97.2% to 98.5%, indicating better handling of invalid and unauthorized requests.

### Security

Unauthorized access blocking improved from 82% to 100% in the simulated verification tests.

Therefore, the small performance overhead is acceptable because it provides a significant improvement in application security.

## 13. Overall Security Performance

Security Before Implementation



Vulnerabilities Detected



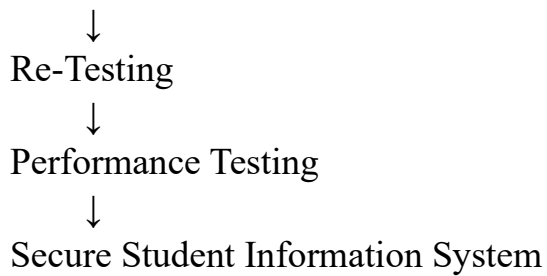
Severity Classification



Security Controls Applied



RBAC Verification



## **14. Results**

The simulated assessment identified 8 vulnerabilities:

- 2 Critical
- 3 High
- 3 Medium

After applying security controls:

- SQL injection protection was implemented.
- RBAC authorization was verified.
- Unauthorized student-record access was blocked.
- Authentication and session security were strengthened.
- Input validation was implemented.
- Audit logging was improved.
- Dependencies were reviewed and updated.
- 10/10 security verification tests passed.

## **15. Conclusion**

The simulation demonstrates that a Secure Student Information Management System with RBAC can significantly improve protection of student data by combining vulnerability detection, severity analysis, security verification and performance evaluation.

The most important security improvement is enforcing server-side authorization for every sensitive operation, ensuring that students, faculty and administrators can access only the information permitted by their roles. Although security controls introduce a